PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Migration vers la cryptographie post-quantique

03-970 ANSSI - Migration vers la cryptographie post-quantique, avis 2022 et 2023 et transition de TLS, SSH et IPsec — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'algorithme de Shor menace la cryptographie à clé publique tandis que Grover impacte la recherche exhaustive en symétrique.
2. L'hybridation combinant un algorithme pré-quantique et un algorithme post-quantique est requise par l'ANSSI pour éviter toute régression de sécurité.
3. La transition des protocoles TLS 1.3, SSHv2 et IPsec repose sur l'hybridation des mécanismes d'établissement de clés.

La menace quantique

Notion	À retenir
L'état de l'art	Prototypes **NISQ** instables ; construction d'un **CRQC** reprogrammable reste un problème ouvert. Plan France : **> 1 milliard €** (2021), **350 millions €** investis en 2 ans (2023).
Impacts cryptographiques	Algorithme de **Shor** brise la clé publique (**RSA**). **Grover** impacte le symétrique : utiliser **AES-256** et hachés **≥ 384 bits** (**SHA-2**, **SHA-3**).
Pourquoi agir	Menace d'**attaque rétroactive** sur les données à longue confidentialité. Nécessité de sortir de la **monoculture algorithmique** de la clé publique actuelle.

Options de réponse à la menace quantique

Notion	À retenir
La QKD écartée	Non considérée comme une contre-mesure appropriée (sauf usages de niche) car elle exige une **infrastructure dédiée** sans capacité de **routage**.
La PQC privilégiée	Voie la plus prometteuse : s'exécute sur les **équipements existants** et peut être déployée par **anticipation**.
Le rôle de l'ANSSI	Rôle **consultatif** (guide de sélection) et **réglementaire** (délivrance de **visas de sécurité** comme les **Critères communs**).

Éléments clés de la PQC et de l'ANSSI

- **Familles d'algorithmes PQC** : réseaux euclidiens, codes correcteurs d'erreurs, isogénies de courbes elliptiques, systèmes polynomiaux multivariés et fonctions de hachage.
- **Normalisation** : campagne lancée par le **NIST** en **2017** (effort accéléré en **2015** après une publication de la **NSA**).
- **Regroupement RISQ** : réunit universitaires, industriels et chercheurs de l'**ANSSI** pour la sécurité post-quantique.
- **Éligibilité aux visas** : pas de liste fermée, mais les algorithmes normalisés par l'**ISO**, l'**UIT** ou l'**ETSI** sont **fortement recommandés**.

Hybridation et transition

Notion	À retenir
Principe hybridation	Combinaison **pré-quantique** et **post-quantique** (ex: dérivation de clé ou concaténation de signatures) pour éviter toute **régression de sécurité**.
Phases 2022	Phase 1 (actuelle) : pré-quantique obligatoire, **PQC optionnelle** (défense en profondeur) ; phase 2 (probablement après **2025**) : **hybridation** ; phase 3 (probablement après **2030**) : hybridation optionnelle.
Accélération 2023	Suivi du **21 décembre 2023** : premiers visas pour produits **hybrides** vers **2024-2025**. Symétrique : au moins **AES-256** et **SHA2-384** (plus conservateur que NIST et BSI).
Cryptoagilité	Capacité à intégrer de nouveaux algorithmes, à prendre en compte dans l'**analyse de risque** malgré les enjeux de **rétrocompatibilité**.

Algorithmes recommandés en 2023

Notion	À retenir
Encapsulation de clé	**ML-KEM** (ex-CRYSTALS-Kyber) : principal KEM, **IND-CCA**, clés éphémères, niveau NIST **5** (AES-256) ou **3** (AES-192). **FrodoKEM** : option conservatrice, plus lourde.
Signatures	**ML-DSA** (ex-Dilithium) : facile, moins compacte. **FN-DSA** (ex-Falcon) : compacte, difficile (nombres flottants), vulnérable canaux auxiliaires. **XMSS/LMS** : à état, hachage, mises à jour. **SLH-DSA** (ex-SPHINCS+) : sans état, conservatrice.

Transition des protocoles

Notion	À retenir
TLS 1.3	Hybridation du handshake (**RFC 8446**) combinant **Diffie-Hellman** et **KEM post-quantique** (**ML-KEM**). Modifie `ClientHello` et `ServerHello`. Supporté par **OpenSSL 3.5.0** et **Chrome**.
SSHv2	Hybridation de l'échange de clés de la **couche transport**. **OpenSSH 9.9** propose deux échanges hybrides, dont un avec **ML-KEM** par défaut.
IPsec	L'échange de clés de **IKEv2** doit être hybridé pour protéger les protocoles **AH** et **ESP**.

Pièges et confusions

⚠ Confondre la menace de Shor (clé publique) avec celle de Grover (symétrique).
⚠ Croire que l'ANSSI approuve le remplacement direct par un algorithme post-quantique seul à court ou moyen terme.
⚠ Considérer la QKD comme une contre-mesure recommandée par l'ANSSI.
⚠ Oublier que l'attaque store now, decrypt later justifie d'agir dès aujourd'hui.

Sigles et définitions

CRQC Ordinateur quantique capable d'exécuter l'algorithme de Shor sur des instances pertinentes et de menacer la cryptographie à clé publique.
PKC Cryptographie à clé publique permettant d'établir des canaux sécurisés et d'authentifier des informations sans secret partagé préalable.
PQC Ensemble d'algorithmes classiques d'établissement de clés et de signature dont la résistance à la menace quantique est conjecturée.
QKD Distribution quantique de clés, échange de clés fondé sur la physique quantique exigeant une infrastructure dédiée.
Hybridation Combinaison d'un algorithme à clé publique pré-quantique éprouvé et d'un algorithme post-quantique.
Cryptoagilité Capacité d'un produit à mettre à jour ses algorithmes cryptographiques sans être rappelé ni remplacé.
KEM Mécanisme d'encapsulation de clé, forme post-quantique de l'établissement de clé.

Auto-test

1. Quel algorithme menace spécifiquement la cryptographie à clé publique ?
2. Quelle est la méthode recommandée par l'ANSSI pour éviter une régression de sécurité lors de la transition ?
3. Quel est le principal KEM recommandé en 2023 ?
4. Quelle attaque justifie d'agir dès aujourd'hui pour protéger les données à longue durée de confidentialité ?
5. Quel protocole propose deux échanges hybrides, dont un avec ML-KEM par défaut dans OpenSSH 9.9 ?

Réponses : **1.** Shor · **2.** L'hybridation · **3.** ML-KEM · **4.** L'attaque store now, decrypt later · **5.** SSHv2

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.